LAPORAN AUDIT KEAMANAN KODE APLIKASI

Sistem Informasi IT Helpdesk & Ticketing (Laravel 12)

DOKUMEN INTERNAL IT

Tanggal Audit: 5 November 2026

NAMA APLIKASI	FRAMEWORK / STACK	METODE PENGUJIAN	TOTAL TEMUAN
IT Helpdesk & Ticketing	**Laravel 12 / PHP 8.4**	**Static Code Analysis (SAST)**	**6 Temuan (2 Tinggi, 3 Sedang, 1 Rendah)**

1. Ringkasan Eksekutif

Audit keamanan dilakukan secara menyeluruh terhadap kode sumber (*source code*) aplikasi IT Helpdesk & Ticketing, meliputi lapisan kontrol akses (*Authorization Policies*), *Controllers*, *Form Requests*, *Middleware*, *Services*, *Models*, serta template tampilan (*Blade Views*). Secara umum arsitektur keamanan aplikasi sudah menerapkan standar yang baik (seperti `TicketPolicy`, transaksi database atomik dengan `lockForUpdate()`, dan penyimpanan berkas privat). Namun ditemukan **6 celah keamanan** yang perlu ditindaklanjuti sebelum aplikasi dioperasikan di lingkungan *production*.

ID	TINGKAT RISIKO	JUDUL TEMUAN	KOMPONEN / FILE TERDAMPAK
SEC-01	TINGGI	Potensi *Stored Cross-Site Scripting (XSS)* pada Rendering Notulensi Rapat	`minutes-section.blade.php`
SEC-02	TINGGI	Celah *IDOR (Insecure Direct Object Reference)* pada Endpoint Pesan/Diskusi Tiket	`ChatController.php`
SEC-03	SEDANG	Bypass Verifikasi Signature Webhook LOA pada Driver `mock` & Fallback Secret Hardcoded	`VerifyLoaWebhookSignature.php` `LoaWebhookController.php`
SEC-04	SEDANG	Rute Registrasi Akun Publik (`/register`) Terbuka dengan Auto-Assign Supervisor	`routes/auth.php` `TicketController.php`
SEC-05	SEDANG	Penyimpanan Metadata MIME Type & Nama Berkas Mengandalkan Header Klien	`TicketService.php`
SEC-06	RENDAH	Risiko *Mass Assignment* pada Atribut Hak Akses (`role` , `is_active`) Model User	`app/Models/User.php`

2. Kontrol Keamanan yang Sudah Berjalan Baik

Otorisasi Berbasis Policy & State Machine
Setiap transisi status tiket divalidasi ganda melalui `TicketPolicy` dan `TicketStateMachine::validateActorAuthority()`.

Pencegahan Race Condition (Concurrency Lock)
Pengambilan tiket (*self-assign*) dan penomoran tiket menggunakan transaksi DB dengan `lockForUpdate()`.

Penyimpanan Berkas Lampiran Privat

Jejak Audit Immutable (Anti-Tamper)

Lampiran disimpan di `Storage::disk('local')` (bukan folder publik) dan diunduh melalui validasi `AttachmentController`.

Setiap perubahan status dan keputusan persetujuan tercatat otomatis ke tabel `ticket_audit_logs` yang tidak dapat diubah.

3. Rincian Temuan & Rekomendasi Perbaikan

SEC-01: Potensi Stored Cross-Site Scripting (XSS) pada Rendering Notulensi Rapat

RISIKO TINGGI

LOKASI KODE

`resources/views/tickets/partials/minutes-section.blade.php` (Baris 68–70)

ANALISIS MASALAH

Kolom `notes` pada notulensi rapat ditampilkan menggunakan tag unescaped Blade `{!! strip_tags($ticket->meetingMinutes->notes, '<p><br><strong>...<a>...<span>') !!}`. Fungsi `strip_tags()` bawaan PHP hanya membatasi nama elemen HTML, tetapi **tidak menghapus atribut event JavaScript** di dalam tag yang diizinkan (seperti atribut `onmouseover`, `onclick`, atau protokol `javascript:` pada tag `<a>`).

REKOMENDASI PERBAIKAN DEFENSIF

Gunakan sintaks escaped standar Blade `{{ $ticket->meetingMinutes->notes }}` dengan class CSS `whitespace-pre-wrap`, atau bersihkan HTML menggunakan pustaka sanitizer berbasis allowlist atribut (seperti *HTMLPurifier* / *Symfony HtmlSanitizer*) sebelum disimpan ke database.

SEC-02: Celah IDOR (Insecure Direct Object Reference) pada Endpoint Pesan/Diskusi

RISIKO TINGGI

LOKASI KODE

`app/Http/Controllers/ChatController.php` — Method `index()` (Baris 19–37) & `store()` (Baris 94–117)

ANALISIS MASALAH

Berbeda dengan `storeDiscussion()` yang sudah memanggil `$this->authorize('view', $ticket)`, endpoint JSON `GET /chat/messages?ticket_id={id}` dan `POST /chat/messages` langsung mengambil serta menyimpan pesan berdasarkan `ticket_id` tanpa memverifikasi apakah pengguna yang sedang login memiliki hak akses untuk melihat tiket tersebut.

REKOMENDASI PERBAIKAN DEFENSIF

Tambahkan pemeriksaan otorisasi tiket pada `ChatController::index()` dan `ChatController::store()` ketika parameter `ticket_id` disertakan:

```
$ticket = \App\Models\Ticket::findOrFail($ticketId);
$this->authorize('view', $ticket);
```

SEC-03: Bypass Verifikasi Signature Webhook LOA pada Driver Mock & Fallback Secret

RISIKO SEDANG

LOKASI KODE

`app/Http/Middleware/VerifyLoaWebhookSignature.php` (Baris 16–23) & `app/Http/Controllers/Api/LoaWebhookController.php` (Baris 30)

ANALISIS MASALAH

Middleware memiliki nilai fallback secret `'loa-webhook-secret-key'` dan meloloskan request tanpa header signature apabila `config('services.loa.driver') === 'mock'`. Jika di server production variabel environment `LOA_DRIVER` masih bernilai `mock` atau `LOA_WEBHOOK_SECRET` lupa diatur, endpoint `/api/v1/webhooks/loa-decision` dapat menerima callback tanpa tanda tangan HMAC-SHA256 yang sah.

REKOMENDASI PERBAIKAN DEFENSIF

Batasi bypass driver `mock` hanya pada environment `local` dan `testing` (`app()->environment(['local', 'testing'])`), serta tolak request dengan status 500/401 di production apabila `LOA_WEBHOOK_SECRET` kosong.

SEC-04: Rute Registrasi Publik (/register) Terbuka dengan Auto-Assign Supervisor

RISIKO SEDANG

LOKASI KODE

`routes/auth.php` (Baris 15–18) & `app/Http/Controllers/TicketController.php` (Baris 114–121, 131–136)

ANALISIS MASALAH

Endpoint `GET /register` dan `POST /register` terbuka bagi pengunjung tanpa autentikasi. Selain itu, saat pengguna baru membuka halaman pembuatan tiket, `TicketController` otomatis menetapkan supervisor pertama di database sebagai atasan langsungnya apabila `supervisor_id` bernilai kosong.

REKOMENDASI PERBAIKAN DEFENSIF

Nonaktifkan rute registrasi mandiri di production (atau batasi dengan konfigurasi environment `ALLOW_PUBLIC_REGISTRATION=false`) sehingga pembuatan akun karyawan hanya dilakukan melalui integrasi SSO atau Administrator IT.

SEC-05: Penyimpanan Metadata MIME Type & Nama Berkas Mengandalkan Header Klien

RISIKO SEDANG

LOKASI KODE

`app/Services/TicketService.php` (Baris 86–90 & 132–136)

ANALISIS MASALAH

Walaupun validasi ekstensi dan tipe berkas sudah dijaga di `StoreTicketRequest` (`mimes:pdf,docx,xlsx,png,jpg,jpeg`), saat menyimpan record ke tabel `ticket_attachments` kode menggunakan `$file->getClientMimeType()` yang membaca header HTTP dari klien (dapat dimanipulasi), serta menyimpan `$file->getClientOriginalName()` tanpa sanitasi karakter kontrol.

REKOMENDASI PERBAIKAN DEFENSIF

Gunakan `$file->getMimeType()` (deteksi *magic bytes* server) untuk kolom `mime_type` dan bungkus nama berkas dengan `basename($file->getClientOriginalName())`.

SEC-06: Risiko Mass Assignment pada Atribut Hak Akses Model User

RISIKO RENDAH

LOKASI KODE

`app/Models/User.php` (Baris 29–40)

ANALISIS MASALAH

Atribut sensitif `role`, `is_active`, `sso_id`, dan `supervisor_id` terdaftar di dalam properti `$fillable` pada model `User`. Meskipun saat ini `ProfileUpdateRequest` hanya mengizinkan field `name` dan `email`, penempatan kolom hak akses pada `$fillable` berisiko memicu eskalasi hak akses (*privilege escalation*) apabila di masa mendatang terdapat endpoint yang memanggil `$user->update($request->all())`.

REKOMENDASI PERBAIKAN DEFENSIF

Keluarkan `role`, `is_active`, dan `sso_id` dari array `$fillable` pada model `User` dan tetapkan nilainya secara eksplisit pada proses provisioning akun.